Access-Controlled Text-to-SQL Without Showing the Model the Restricted Schema: Results on Two Public Benchmarks, and a Fail-Closed Bug They Exposed

Ashish Sinha
Independent
https://github.com/ashishsinha1602/schemagate

October 2026

Abstract

Text-to-SQL systems deployed inside organisations must answer the questions a user may ask and refuse the ones they may not. Two recent benchmarks measure exactly this: the RBAC Text-to-SQL benchmark of Fei et al. and Spider-ACL of Klisura et al., whose labels come from PostgreSQL itself. Both report that restricting the schema shown to the model is not enough on its own, because models approximate an answer from the columns that remain. We evaluate schemagate, an open-source library, which combines three mechanisms: (i) the caller's permissions decide which tables and columns enter the prompt, so restricted names are never shown; (ii) one line tells the model its view is partial, without naming what is withheld; and (iii) every generated query is checked against the caller's permissions before it runs. Scored by each benchmark's own protocol, it reaches an AC-F1 of 90.1 on BIRD in the RBAC benchmark (best reported in that paper: 88.1, same model) and a refusal F1 of 0.984 on all 19,624 Spider-ACL records (best reported: 0.933). No query it answered read a table or column outside the caller's grants, which we verify independently of the mechanism that enforces it. We also report the negative results: on Spider the RBAC result ties the same model and trails the paper's best; adding column descriptions made violations worse; and the first Spider-ACL pilot exposed a bug in which a fail-closed query check silently refused valid SQL, which we argue is a general hazard of fail-closed designs.

1 Introduction

A natural-language interface to a database inherits the database's access rules. A question about salaries from a user without the payroll role should be refused, and refused before any data is read. The common approaches are (a) to describe the policy to the model in the prompt and trust it to comply, and (b) to show the model only the schema the caller may read. Fei et al. [1] find that (a) leaves violations at several percent even for strong models, and that (b) fails in a different way: the model, unaware anything is missing, answers anyway from the columns it can see. Klisura et al. [2] report a similar trade-off between refusing correctly and answering permitted questions.

This report evaluates a combination of (b) with two additions, on both benchmarks, using each benchmark's own scoring code or scoring rule unchanged. Our contributions are measurements, not a new model: no fine-tuning is involved.

2 Method

Identity-scoped schema selection. The library reflects the database into a catalogue. Each table, view and column carries the roles that may read it, either from a configuration or from the database's own GRANTs. For a question and a caller, it selects the relevant objects from those the caller may read and renders their DDL for the prompt. Restricted objects are absent rather than ranked low.

Restriction notice. When the caller cannot see some part of the catalogue, the rendered schema begins with one line: *"This caller may read only part of this database: some tables and columns are not shown. Answer only if the tables and columns below directly hold what the question asks for. If it would need data that is not shown, reply INSUFFICIENT; do not approximate it from other columns."* It names nothing that is withheld.

Scope check. Before a generated query runs, the tables and columns it references are extracted twice, by pattern readers and by a SQL parser (sqlglot) in the database's dialect, and the query is refused if either finds a name the caller may not read, or if it cannot be parsed. `SELECT *` over a table with withheld columns is refused.

3 Benchmarks and setup

RBAC Text-to-SQL [1]. Spider [3] and BIRD [4] questions, each paired with a role and a column-level policy. We ran the authors' evaluator unmodified with `--fair_comparison --num_trials 5 --execute_sql`, using claude-sonnet-4-5, the model behind the paper's best results. Metrics: AC-F1, SafeEX, violation rate (any answer to a forbidden question), over-refusal, and the rate of SQL that reads outside the policy.

Spider-ACL [2]. 19,624 Spider question–role pairs; roles are PostgreSQL GRANTs and the label is PERMIT or DENY as PostgreSQL returned when the reference query ran as that role (11,529 DENY). We score refusal precision, recall and F1 with refusal as the positive class, following the paper, using claude-sonnet-5-5 on all records.

4 Results

BIRD (10,175 rows)	AC-F1	SafeEX	Violation	Over-refusal	Out-of-policy SQL
schemagate	**90.14** $\pm$ 0.32	**68.38** $\pm$ 1.07	**5.44** $\pm$ 0.19	1.98	**0.00**
without scope check	84.69 $\pm$ 0.69	69.14 $\pm$ 0.85	11.25 $\pm$ 0.44	1.23	3.78
Paper, same model, policy in prompt	88.12 $\pm$ 0.90	65.02 $\pm$ 0.89	7.37 $\pm$ 0.49	1.81	–
Paper, best schema-only (GPT-5-mini)	72.46	–	26.72	0.33	–
Spider (6,926 rows)					
schemagate	93.02 $\pm$ 0.37	78.87 $\pm$ 1.05	5.05 $\pm$ 0.49	2.59	**0.00**
without scope check	90.68 $\pm$ 0.31	79.56 $\pm$ 1.05	8.67 $\pm$ 0.57	1.91	2.01
Paper, same model	93.03 $\pm$ 0.48	80.99 $\pm$ 0.86	4.55 $\pm$ 0.22	3.01	–
Paper, best (DeepSeek V3.2-Reasoning)	**95.94** $\pm$ 0.37	75.73 $\pm$ 1.19	**1.97** $\pm$ 0.25	2.36	–

Table 1: RBAC Text-to-SQL benchmark, authors' evaluator, mean $\pm$ s.d. over five trials. On BIRD the same-model result is also the best of the paper's thirteen models.

On BIRD, the combination exceeds every configuration reported in [1] on AC-F1, SafeEX and violations. On Spider it ties the same model and trails the paper's best model. Removing the scope check raises the violation rate from 5.4% to 11.3% on BIRD and from 5.1% to 8.7% on Spider, and is the only one of our configurations that produced out-of-policy SQL.

Spider-ACL	Refusal P	Refusal R	Refusal F1	DENY answered
schemagate, all 19,624 records	0.985	0.982	**0.984**	1.8% (206/11,529)
schemagate, 600 records not used in development	0.989	0.983	0.986	1.7%
Paper, best (LoRA-tuned Mistral-7B)	0.936	0.929	0.933	–
Paper, best without fine-tuning (DeepSeek-R1 + verifier)	0.898	0.868	0.883	–

Table 2: Spider-ACL. Confusion counts for the full run: TP 11,323, FP 173, FN 206, TN 7,922.

Independent audit. Every one of the 8,128 queries answered on Spider-ACL was parsed with sqlglot and its tables and columns compared with the record's GRANTs, separately from the scope check that enforces the rule. None referenced an ungranted table or column. Two queries the parser could not read (the model appended prose after the SQL) were checked by hand.

5 Ablations and negative results

Restriction notice. On a 100-question BIRD pilot (one trial), with the scope check on, violations fell from 16% to 5% and AC-F1 rose from 0.818 to 0.921 with the notice. Its wording was chosen on that pilot, whose questions belong to the test set; re-scoring BIRD with those 100 questions removed gives AC-F1 90.08 ± 0.25, unchanged. The full runs were not repeated without the notice.

Column descriptions hurt. Loading BIRD's column descriptions as comments raised violations on the same pilot (16% to 26% without the notice): richer notes on the visible columns helped the model construct substitutes for questions it should have refused.

A fail-closed bug. The first Spider-ACL pilot (200 records) scored far lower than expected. 32 of its 33 wrong refusals had one cause: the pattern reader matched `table [AS] alias` case-sensitively, so `FROM students AS T1` was read as two tables, and the unknown "T1" was refused. Because the check fails closed, the bug caused no leak and no error, only refusals that looked like caution. Our own tests had not caught it; a benchmark with externally produced labels did, within two days. We think this generalises: a fail-closed guard converts its own defects into plausible refusals, so its false-refusal rate must be measured, not only its leak rate.

6 Limitations

The models differ from most of those in the original papers: the RBAC comparison is same-model, but the Spider-ACL systems of [2] used 2024–25 models, and part of that gap is the model. On Spider-ACL we score only the answer-or-refuse decision, not execution accuracy. BIRD-ACL and the RBAC benchmark's LiveSQLBench subset were not run. The BIRD databases used are the 2024-06 dev release; [1] used a 2025-11 release. Neither result has yet been reproduced by the benchmarks' authors; both have been sent to them.

7 Reproducibility

Code, harnesses (`benchmarks/rbac_text2sql.py`, `benchmarks/acl_text2sql.py`), the evaluator reports and every Spider-ACL decision with its SQL are public at https://github.com/ashishsinha1602/schemagate (release 1.6.1, Apache-2.0).

References

[1] Y. Fei, Y. Jiang, Y. Yang, X. Xiao. Benchmarking Text-to-SQL under Role-Based Access Control. *Proc. ACM Manag. Data* (SIGMOD 2027). arXiv:2607.22115.

[2] Đ. Klisura, J. Khoury, A. Kundu, R. Krishnan, A. Rios. Role-Conditioned Refusals: Evaluating Access Control Reasoning in Large Language Models. *Findings of EACL 2026*, pp. 6018–6034.

[3] T. Yu et al. Spider: A Large-Scale Human-Labeled Dataset for Complex and Cross-Domain Semantic Parsing and Text-to-SQL Task. EMNLP 2018.

[4] J. Li et al. Can LLM Already Serve as a Database Interface? A Big Bench for Large-Scale Database Grounded Text-to-SQLs. NeurIPS 2023.